

Penetration Test Report

Report Type: Penetration Testing

Target: 172.18.0.3

Analyst: Phangasasa Muhlaba

Date: 2026-05-19 17:17

CONFIDENTIAL - For Authorized Personnel Only

Cybersecurity Report

Executive Summary

This report presents the findings from a security assessment conducted against the target system. A total of 13 security findings were identified across network, web application, and directory enumeration assessments. Of these, 0 were rated Critical severity requiring immediate remediation, 4 High severity findings requiring urgent attention, 3 Medium severity findings, and 5 Low severity informational findings. All findings include detailed descriptions, evidence, and remediation guidance.

Total	Critical	High	Medium	Low
13	0	4	3	5

Network Scan Findings (nmap)

Network scanning was performed against 172.18.0.3 using nmap. The following open ports and services were identified. Each exposed service increases the attack surface and should be reviewed.

Finding 1: 22/tcp - SSH

Port / State: 22/tcp (open)

Service: ssh

Severity: Medium

Description:

SSH service exposed. Ensure strong authentication, disable root login, use key-based auth.

Finding 2: 80/tcp - HTTP

Port / State: 80/tcp (open)

Service: http

Severity: Medium

Description:

HTTP service exposed without encryption. Consider redirecting to HTTPS.

Finding 3: 443/tcp - HTTPS

Port / State: 443/tcp (open)

Service: https

Severity: Info

Description:

HTTPS service running. Verify TLS version and cipher suites.

Finding 4: 3306/tcp - MYSQL

Cybersecurity Report

Port / State: 3306/tcp (open)

Service: mysql

Severity: High

Description:

MySQL database port exposed. Should not be publicly accessible. Restrict to localhost only.

Finding 5: 8080/tcp - HTTP-PROXY

Port / State: 8080/tcp (open)

Service: http-proxy

Severity: Medium

Description:

HTTP proxy service detected. Verify this is intentional and properly secured.

Web Vulnerability Findings (nikto)

Web application scanning was performed using nikto. The following vulnerabilities and misconfigurations were identified. Each finding includes a description of the risk and recommended remediation steps.

Finding 1: Server Version Disclosure

Severity: Low

Description:

The web server is disclosing its version information in response headers. This helps attackers identify known vulnerabilities for the specific version.

Remediation:

Configure ServerTokens Prod and ServerSignature Off in Apache, or equivalent for your web server.

Finding 2: Missing X-Frame-Options Header

Severity: High

Description:

The X-Frame-Options HTTP response header is not present. This leaves the application vulnerable to clickjacking attacks where an attacker embeds the site in an invisible iframe.

Remediation:

Add "Header always set X-Frame-Options DENY" to Apache configuration or equivalent for your web server.

Finding 3: Missing X-Content-Type-Options Header

Severity: Medium

Description:

Cybersecurity Report

The X-Content-Type-Options header is not set. This allows browsers to MIME-sniff responses away from the declared content-type, enabling certain attack vectors.

Remediation:

Add "Header always set X-Content-Type-Options nosniff" to your web server configuration.

Finding 4: Outdated Software Version Detected

Severity:

Medium

Description:

An outdated version of server software was detected. Outdated software may contain known vulnerabilities that have been publicly disclosed.

Remediation:

Update all server software to the latest stable version. Subscribe to security advisories for your software stack.

Finding 5: Sensitive Directory Exposed

Severity:

High

Description:

A configuration directory is publicly accessible. Configuration files may contain database credentials, API keys, and other sensitive information.

Remediation:

Restrict access to configuration directories using web server access controls. Add "Require all denied" directives for sensitive directories.

Finding 6: PHP Info Page Exposed

Severity:

High

Description:

A phpinfo() page is publicly accessible. This page reveals sensitive server configuration including PHP version, loaded modules, file paths, and environment variables.

Remediation:

Remove or restrict access to phpinfo.php immediately. This file should never be accessible in a production environment.

Finding 7: Administrative Interface Exposed

Severity:

Medium

Description:

An administrative login page is publicly accessible. This increases the attack surface and risk of brute force attacks.

Remediation:

Restrict access to admin interfaces by IP address. Implement account lockout after failed attempts and enable MFA.

Cybersecurity Report

Finding 8: Session Cookie Missing HttpOnly Flag

Severity:

High

Description:

The session cookie is set without the HttpOnly flag. This means the cookie can be accessed by client-side JavaScript, making it vulnerable to theft via Cross-Site Scripting (XSS) attacks.

Remediation:

Set `session.cookie_httponly = 1` in `php.ini` or use `setcookie()` with the `httponly` parameter set to true.

Directory Enumeration Findings (dirb)

Directory and file enumeration was performed using dirb. The following accessible paths were discovered. Exposed directories and files may reveal sensitive information or provide additional attack vectors.

No directories or files found.

Recommendations

Critical/High:

Immediately patch or mitigate all Critical and High severity findings within 7 days.

Network Exposure:

Review all exposed services and close any ports not required for business operations. Apply firewall rules to restrict access to sensitive services like MySQL (3306).

Web Security:

Implement all missing security headers (X-Frame-Options, X-Content-Type-Options, Content-Security-Policy) across all web applications.

Session Security:

Enforce HttpOnly and Secure flags on all session cookies to prevent XSS-based session theft.

Information Disclosure:

Remove or restrict access to `phpinfo.php`, configuration directories, and any files that expose server information.

Patch Management:

Establish a patch management process to ensure all software is kept up to date within 30 days of security patches being released.

WAF:

Implement a Web Application Firewall (WAF) to provide an additional layer of protection against common web attacks.